

Security Report Remediation Summary

Reports: frontend-security report.html | backend-report.html | security report.pdf

Frontend: affiliatechatbox.com (affiliatechatboxweb)

Admin: admin-panel-omd.netlify.app (Online_media_tools_ADMIN_PANEL)

Date: 29 June 2026

NOTE: Code fixes are done. Re-deploy both sites to Netlify, then re-run ZAP scan. Some alerts are from Cloudflare/Google and cannot be fixed in app code.

1. Executive Summary

Category	Count	Notes
Fully solved in our code	14	Headers, avatars, fonts, ELMAH, error pages, HTTPS redirects
Partially solved	3	Third-party CORS; RSC error disclosure
Not fixable from app code	6	Cloudflare cookies, CDN headers, third-party CORS, timestamps
Informational (no action)	7	localStorage, cache, modern web app, fuzzer

2. Frontend (affiliatechatbox.com) - SOLVED

Alert	Risk	Status	Fix / Files
CSP Header Not Set	Medium	SOLVED	CSP in next.config.ts + netlify.toml + security-headers.ts
Missing Anti-clickjacking	Medium	SOLVED	X-Frame-Options DENY + frame-ancestors none
Sub Resource Integrity Missing	Medium	SOLVED	Local SVG avatars replace ui-avatars.com
X-Content-Type-Options Missing	Low	SOLVED	nosniff header added
HSTS Not Set	Low	SOLVED	Strict-Transport-Security (production)
X-Powered-By Leak	Low	SOLVED	poweredByHeader: false in Next.js
HTTPS via HTTP	Low	SOLVED	HTTP to HTTPS 301 redirects in netlify.toml

Partially Solved

Cross-Domain CORS	Medium	PARTIAL	Fixed our avatars. Cloudflare cdn-cgi and Google still flagged.
Application Error Disclosure	Low	PARTIAL	Added error.tsx pages. May still flag if RSC returns 500.

Not Fixable From App Code

Alert	Why / How to address
Cookie SameSite=None	Cloudflare cf_clearance cookie. Fix via Cloudflare dashboard. Usually accepted.
Server Header Leak	Cloudflare/CDN sets Server header. Cloudflare Transform Rules or accept.
Timestamp Disclosure	Unix timestamps in API JSON. Normal data - document as accepted false positive.
Third-party CORS	Google, Cloudflare, Mozilla control their CORS. Cannot fix from our code.
HSTS on external URLs	Scanner checked Google/Mozilla - not our domain. No action.

Informational - No Action Required

localStorage disclosure	UI preference storage. Report says no action needed.
Cache-control review	Informational caching note.
Retrieved from Cache	Informational - CDN caching working.

3. Admin (admin-panel-omd.netlify.app) - SOLVED

Alert	Risk	Status	Fix / Files
CSP Header Not Set	Medium	SOLVED	netlify.toml security headers
ELMAH Information Leak	Medium	SOLVED	/elmah.axd returns 404 (SPA false positive fixed)

Missing Anti-clickjacking	Medium	SOLVED	X-Frame-Options + CSP frame-ancestors
Sub Resource Integrity Missing	Medium	SOLVED	Removed Google Fonts; system fonts used
X-Content-Type-Options Missing	Low	SOLVED	nosniff header
HSTS Not Set	Low	SOLVED	HSTS in netlify.toml

Partial / Not Fixable (Admin)

Cross-Domain CORS	PARTIAL - fonts.googleapis.com is third-party if still prefetched
Server Header Leak	NOT FIXABLE - Netlify infrastructure header
Timestamp Disclosure	NOT FIXABLE - normal API timestamps
Modern Web App / Cache / Fuzzer	INFORMATIONAL - no action required

4. Deployment Checklist

1. Deploy affiliatechatboxweb to Netlify (affiliatechatbox.com)
2. Deploy Online_media_tools_ADMIN_PANEL to Netlify (admin-panel-omd.netlify.app)
3. Verify: curl -I https://affiliatechatbox.com
4. Verify: curl -I https://admin-panel-omd.netlify.app/elmah.axd (expect 404)
5. Re-run ZAP scan on both URLs
6. Document remaining third-party findings as accepted risks

5. Files Modified

affiliatechatboxweb

next.config.ts, netlify.toml, src/lib/security-headers.ts, src/lib/user-profile-image.ts, src/app/error.tsx, global-error.tsx, not-found.tsx, chats.tsx, use-inbox-preview-chats.ts

Online_media_tools_ADMIN_PANEL

netlify.toml, public/404.html, public/index.html, _variables.scss, App.css